



TASK 06

Network Security Monitoring and Analysis

1. Understanding Security Assessment

Introduction:

A **Security Assessment** is a systematic process of evaluating an organization's information systems, networks, and applications to identify security weaknesses, misconfigurations, and vulnerabilities that could be exploited by attackers.

The primary goal of a security assessment is to:

1. Identify potential threats and vulnerabilities
2. Evaluate the effectiveness of existing security controls
3. Reduce risk exposure
4. Improve overall security posture

Security assessments can be performed using open-source tools, manual testing techniques, and standardized security frameworks without relying on expensive commercial tools.

Industry frameworks such as **NIST Cybersecurity Framework (CSF)** provide structured guidelines for identifying, protecting, detecting, responding to, and recovering from cybersecurity incidents.

Types of Security Testing

Security testing is categorized into different types based on objectives and depth of analysis.

1. Vulnerability Assessment (VA)

A **Vulnerability Assessment** is the process of scanning systems to identify known security vulnerabilities using automated tools.

It focuses on:

- Detecting outdated software
- Identifying open ports and exposed services



- Finding weak credentials
- Checking misconfigurations

vulnerabilities such as:

- vsftpd backdoor
- Default database credentials
- Remote Code Execution vulnerabilities

2. Penetration Testing (PT)

Penetration Testing simulates real-world cyberattacks to exploit vulnerabilities identified during assessment.

Unlike vulnerability scanning, penetration testing:

- Actively exploits vulnerabilities
- Demonstrates real impact
- Validates whether vulnerabilities are exploitable
- Provides proof-of-concept evidence

Penetration testing follows structured phases:

- Reconnaissance
- Scanning
- Exploitation
- Post-exploitation
- Reporting

Example Tools:

- Kali Linux
- Metasploit Framework

In this lab environment, Kali Linux tools were used to analyze and potentially exploit identified vulnerabilities.

3. Compliance Testing

Compliance Testing ensures that systems and processes align with industry security standards, regulatory requirements, and best practice frameworks. Organizations are often required to comply with standards such as ISO 27001, GDPR, HIPAA, and CIS Benchmarks to maintain data protection and security governance. Compliance testing involves validating system configurations, reviewing access control mechanisms, verifying encryption implementations, and ensuring proper patch management practices are in place.



2. VAPT Methodology

Vulnerability Assessment and Penetration Testing (VAPT) follows a structured methodology to ensure that security testing is systematic, controlled, and aligned with industry best practices. Instead of performing random scans or attacks, VAPT divides the assessment into clearly defined phases. This structured approach ensures that vulnerabilities are properly identified, validated, prioritized, and documented.

The VAPT methodology used in this project consists of the following key phases:

- Planning
- Discovery
- Attack (Exploitation)
- Post-Exploitation
- Reporting

Each phase plays a critical role in ensuring a comprehensive security evaluation.

1. Planning Phase

The planning phase defines the scope, objectives, and boundaries of the assessment. It ensures that testing is authorized and controlled.

During this phase, the following elements were defined:

- Target system: Metasploitable virtual machine
- Attacker system: Kali Linux
- Environment: VirtualBox isolated lab network
- Testing approach: Controlled vulnerability assessment

The purpose of planning is to prevent unauthorized testing and to clearly document what systems are included in the engagement. Even in a lab environment, defining scope demonstrates ethical hacking practices and professional conduct.

2. Discovery Phase

The discovery phase focuses on gathering technical information about the target system. This phase includes network scanning and vulnerability scanning to identify exposed services and potential weaknesses.

Key activities performed during discovery:

- Identifying open ports and running services
- Detecting outdated software versions
- Mapping services to known CVEs
- Analyzing CVSS severity scores



Tools used:

- Nmap (for network scanning)
- OpenVAS (for vulnerability scanning)

In this project, OpenVAS identified multiple critical vulnerabilities such as remote code execution services, default database credentials, FTP backdoor vulnerabilities, and an end-of-life operating system.

The discovery phase provides the foundation for exploitation by identifying which vulnerabilities are most critical and potentially exploitable.

3. Attack (Exploitation) Phase

The attack phase involves validating vulnerabilities by attempting controlled exploitation. Unlike vulnerability scanning, which only detects weaknesses, exploitation demonstrates real-world impact.

Objectives of this phase include:

- Confirming whether vulnerabilities are exploitable
- Demonstrating unauthorized access possibilities
- Assessing impact severity

In this lab setup, vulnerabilities such as the vsftpd backdoor, default credentials in MySQL and PostgreSQL, and remote execution services were identified as high-risk attack vectors. Exploitation tools like Metasploit Framework can be used to validate these vulnerabilities.

This phase helps convert theoretical risk into practical security impact.

4. Post-Exploitation Phase

Post-exploitation assesses the level of access obtained after successful exploitation. This phase evaluates how far an attacker could move within the system.

Typical post-exploitation activities include:

- Privilege escalation
- Accessing sensitive files
- Maintaining persistence
- Lateral movement

Example if root-level access is achieved through a backdoor service, it indicates compromise.

5. Reporting Phase

The reporting phase is the final and most important stage of the VAPT process. All findings are documented in a structured format that includes severity levels, CVSS scores, CVE references, screenshots, and remediation steps.



A professional VAPT report typically contains:

- Executive Summary
- Scope and Methodology
- Technical Findings
- Risk Assessment
- Remediation Recommendations



3. Security Standards & Compliance

Security standards and compliance frameworks provide structured guidelines for protecting information systems, managing risk, and ensuring data security. Organizations use these standards to establish security controls, demonstrate due diligence, and comply with regulatory requirements. Although this project was conducted in a controlled lab environment, the assessment methodology aligns with industry-recognized security standards and best practices.

ISO 27001

ISO/IEC 27001 is an international standard for Information Security Management Systems (ISMS). It provides a framework for managing sensitive information and implementing security controls to reduce risk.

ISO 27001 focuses on:

- Risk assessment and risk treatment
- Access control management
- Asset management
- Cryptographic controls
- Incident response planning
- Continuous improvement

In the context of this assessment, identifying default credentials, exposed services, and outdated operating systems reflects ISO 27001 control requirements related to secure configuration management and vulnerability management.

For example:

- Detection of default MySQL credentials violates access control policies.
- Use of an End-of-Life operating system violates patch management controls.

GDPR (General Data Protection Regulation)

GDPR is a European data protection regulation focused on protecting personal data and ensuring privacy rights.

Key GDPR security principles include:

- Data confidentiality and integrity
- Protection against unauthorized access
- Secure processing of personal data
- Timely detection and response to security incidents



Although this lab system does not process real personal data, vulnerabilities such as remote code execution, weak authentication, and open services would pose serious GDPR violations in a real-world production system.

This assessment demonstrates how unpatched systems and weak credentials could lead to data breaches.

HIPAA (Health Insurance Portability and Accountability Act)

HIPAA is a U.S. regulation designed to protect sensitive healthcare information.

Security requirements under HIPAA include:

- Access control mechanisms
- Audit controls
- Integrity controls
- Transmission security

If a healthcare organization operated a system similar to the vulnerable lab environment, exposed services such as FTP, REXEC, or weak database authentication would directly violate HIPAA security safeguards.

OWASP Top 10

The OWASP Top 10 is a widely recognized list of the most critical web application security risks.

Some relevant categories identified in this assessment include:

- A01: Broken Access Control (default credentials)
- A02: Cryptographic Failures (unencrypted services)
- A06: Vulnerable and Outdated Components (Ubuntu 8.04 EOL)
- A03: Injection (Remote Code Execution vulnerabilities)

By mapping discovered vulnerabilities to OWASP categories, organizations can prioritize remediation based on industry-recognized risk trends.

CIS Benchmarks

CIS Benchmarks provide configuration best practices for securing operating systems, servers, and applications.

CIS recommendations typically include:

- Disabling unused services
- Removing default credentials
- Enforcing strong password policies
- Applying security patches



- Minimizing open ports

The vulnerabilities identified during the OpenVAS scan, such as exposed remote services and default database credentials, demonstrate deviations from CIS hardening guidelines.

Importance of Compliance Alignment

Aligning vulnerability assessments with security standards ensures:

- Regulatory compliance
- Reduced legal risk
- Improved organizational security maturity
- Stronger governance and accountability



4. Risk Assessment Basics

Risk assessment is the process of evaluating identified vulnerabilities to determine their potential impact on an organization. Not all vulnerabilities pose the same level of risk. Some may lead to complete system compromise, while others may have minimal impact. Therefore, risk assessment helps prioritize remediation efforts based on severity, likelihood, and business impact.

In this project, risk assessment was performed using two main approaches:

- CVSS Scoring System
- Risk Matrix (Likelihood vs. Impact Model)

Both methods help convert technical findings into measurable security risk levels.

CVSS (Common Vulnerability Scoring System)

CVSS is a standardized scoring system used to measure the severity of vulnerabilities. It provides a numerical score ranging from 0.0 to 10.0, where higher scores indicate greater severity.

CVSS scoring considers:

- Attack vector (Network, Local, Physical)
- Attack complexity
- Privileges required
- User interaction required
- Impact on confidentiality, integrity, and availability

Severity classification:

- 9.0 – 10.0 → Critical
- 7.0 – 8.9 → High
- 4.0 – 6.9 → Medium
- 0.1 – 3.9 → Low

During the OpenVAS scan of the Metasploitable system, multiple vulnerabilities were rated Critical (CVSS 9.8–10.0), including remote code execution services, default database credentials, and backdoor vulnerabilities. These high scores indicate that the system is highly exploitable with severe impact potential.

Risk Matrix (Likelihood vs. Impact)

While CVSS provides technical severity, organizations also evaluate business risk using a Risk Matrix. This model categorizes risk based on two dimensions:

- Likelihood (Probability of exploitation)
- Impact (Damage if exploited)



A simple 3x3 risk matrix includes:

Likelihood:

- Low
- Medium
- High

Impact:

- Low
- Medium
- High

Example Risk Categorization from this Assessment:

- vsftpd Backdoor → High Likelihood + High Impact → Critical Risk
- Default MySQL Credentials → High Likelihood + High Impact → Critical Risk
- Anonymous FTP Login → Medium Likelihood + Medium Impact → Medium Risk
- Open HTTP Methods (PUT/DELETE) → Medium Likelihood + High Impact → High Risk

This matrix helps prioritize which vulnerabilities must be addressed immediately versus those that can be scheduled for remediation.

Risk Prioritization Strategy

Based on CVSS scores and risk matrix analysis, vulnerabilities should be remediated in the following order:

1. Critical vulnerabilities (Remote Code Execution, Backdoors, Default Credentials)
2. High-risk vulnerabilities (Weak authentication, insecure services)
3. Medium-risk vulnerabilities (Configuration weaknesses)
4. Low-risk vulnerabilities (Minor information disclosure issues)

Proper risk prioritization ensures that limited resources are focused on the most dangerous threats first.

Importance of Risk Assessment

Risk assessment is essential because it:

- Converts technical vulnerabilities into business risk
- Helps management understand potential impact
- Supports compliance requirements

In this lab-based assessment, the presence of multiple Critical vulnerabilities indicates a highly insecure system that would be unacceptable in a real-world production environment.



5. Common Vulnerabilities Identified

During the vulnerability assessment of the Metasploitable system, multiple security weaknesses were identified. These vulnerabilities reflect common real-world security issues found in improperly configured or outdated systems. The findings demonstrate how misconfigurations, outdated software, and weak authentication mechanisms significantly increase the attack surface of a system.

The vulnerabilities identified can be broadly categorized into:

- Network-level vulnerabilities
- Web application vulnerabilities
- Authentication weaknesses
- Outdated software and system misconfigurations

Each category is discussed below.

Network-Level Vulnerabilities

Network vulnerabilities occur when unnecessary or insecure services are exposed to the network.

Open ports and unencrypted services increase the likelihood of remote exploitation.

The assessment identified:

- Open remote execution services (REXEC, rsh)
- DistCC remote command execution vulnerability
- VNC service with weak authentication
- Exposed FTP services
- Multiple high-risk open ports

These services allow attackers to remotely execute commands, brute-force credentials, or intercept unencrypted communication. Exposing such services violates basic system hardening practices recommended by CIS benchmarks.

Remote Code Execution (RCE) Vulnerabilities

Remote Code Execution vulnerabilities are among the most critical security issues because they allow attackers to execute arbitrary commands on the target system.

Examples identified in this assessment include:

- vsftpd 2.3.4 backdoor vulnerability
- DistCC RCE vulnerability
- TWiki command execution vulnerability
- PHP CGI remote execution vulnerability

These vulnerabilities received high CVSS scores (9.8–10.0), indicating severe impact. If exploited, attackers could gain shell access and potentially full system control.



Default and Weak Credentials

Weak authentication remains one of the most common causes of system compromise.

The scan revealed:

- MySQL default credentials (root with empty password)
- PostgreSQL default credentials (postgres:postgres)
- FTP weak/default credentials
- Anonymous FTP login enabled

Default credentials are widely exploited by automated bots and attackers. Failure to change default passwords significantly increases the likelihood of unauthorized access.

Outdated and End-of-Life Software

Running outdated or unsupported software introduces serious security risks. Systems that no longer receive security patches are vulnerable to publicly known exploits.

The assessment identified:

- Ubuntu 8.04 (End-of-Life since 2013)
- Outdated PHP version vulnerable to CVE-2012-1823
- Legacy services with known CVEs

End-of-life systems violate patch management best practices and compliance standards such as ISO 27001 and CIS controls.

Insecure Service Configurations

Misconfigured services often allow attackers to perform unintended actions.

Examples identified:

- HTTP PUT and DELETE methods enabled
- Unencrypted FTP login allowed
- VNC unencrypted communication
- STARTTLS command injection vulnerability

Such misconfigurations may not always involve software bugs but still create significant security exposure.

Lessons from Identified Vulnerabilities

The vulnerabilities discovered in this lab highlight several important security lessons:

- Disable unnecessary services
- Change default credentials immediately
- Regularly apply security patches
- Use encrypted communication protocols



6. Documentation Fundamentals

Documentation is one of the most critical components of a security assessment. Even the most technically advanced testing is incomplete without proper reporting. Security documentation ensures that findings are clearly communicated to stakeholders, management, and technical teams responsible for remediation.

The purpose of documentation is not only to list vulnerabilities but to explain their impact, risk level, and recommended fixes in a structured and understandable format.

Effective security documentation should be:

- Clear and concise
- Technically accurate
- Structured and organized
- Supported with evidence (screenshots, CVSS scores, logs)
- Action-oriented (includes remediation steps)

Importance of Proper Documentation

Security findings must be presented in a way that both technical and non-technical stakeholders can understand. While technical teams require detailed vulnerability data, management requires high-level summaries to assess business risk.

Good documentation helps in:

- Risk prioritization
- Audit and compliance verification
- Tracking remediation progress
- Demonstrating professional competency
- Maintaining historical security records

In professional environments, poorly documented findings may lead to vulnerabilities being ignored or misunderstood.

Documentation Tools

Several tools can be used to document security findings, depending on project complexity and collaboration requirements.

Common documentation tools include:

- Dradis CE (collaborative penetration testing reporting)
- CherryTree (structured technical note-taking)
- Spreadsheets (Excel / Google Sheets)
- Word processors (Microsoft Word, LibreOffice Writer)



For this assessment, a structured PDF report format is being used to summarize theoretical knowledge, practical findings, risk assessment, and remediation recommendations.

Key Components of a Security Report

A professional VAPT report typically includes the following sections:

- Executive Summary
- Scope and Objectives
- Methodology
- Testing Environment
- Technical Findings
- Risk Assessment
- Remediation Recommendations
- Conclusion

Each vulnerability should include:

- Affected IP address
- Port number
- Service name
- CVSS score
- CVE reference (if applicable)
- Description of the issue
- Impact explanation
- Remediation steps

This structured approach ensures clarity and consistency across the report.

Evidence Collection

Supporting evidence strengthens the credibility of the assessment. Evidence may include:

- OpenVAS scan summaries
- Vulnerability detail pages
- Terminal outputs
- Network connectivity verification
- Configuration screenshots

Screenshots should be relevant, clear, and properly labeled within the report.



Best Practices in Documentation

To maintain professionalism and clarity:

- Avoid unnecessary technical jargon in executive summaries
- Use consistent formatting
- Categorize vulnerabilities by severity
- Prioritize critical issues
- Provide actionable remediation steps

A well-documented report demonstrates both technical expertise and professional communication skills.

Executive Summary

The objective of this security assessment was to evaluate the security posture of the Metasploitable virtual machine within a controlled lab environment. The assessment was conducted using Kali Linux and OpenVAS to simulate a structured vulnerability assessment process aligned with VAPT methodology.

The scan results identified multiple critical vulnerabilities, including remote code execution flaws, default credentials, backdoor services, and insecure configurations. Several vulnerabilities were assigned CVSS scores above 9.0, indicating high exploitability and severe impact.

The findings demonstrate that the target system is highly insecure and would pose significant risk in a production environment. Immediate remediation is required for critical vulnerabilities, followed by systematic hardening and patch management.

This assessment highlights the importance of proactive vulnerability management, risk prioritization, and professional documentation in maintaining organizational security.



Practical Application

1. Setup Testing Environment

The testing environment was configured in a controlled virtual lab setup to safely perform vulnerability assessment and penetration testing without affecting any production systems.

The lab environment consisted of two virtual machines hosted on Oracle VirtualBox:

- **Attacker Machine:** Kali Linux
- **Target Machine:** Metasploitable (intentionally vulnerable system)

Both virtual machines were configured within an isolated Host-Only network to ensure secure internal communication. This setup allowed controlled testing while preventing external network exposure.

Installation of Kali Linux

Kali Linux was installed as the attacker machine. Kali Linux is a specialized penetration testing operating system that includes pre-installed security tools such as:

- Nmap
- OpenVAS (Greenbone)
- Metasploit Framework
- Nikto

The system was updated and verified to ensure proper tool availability.

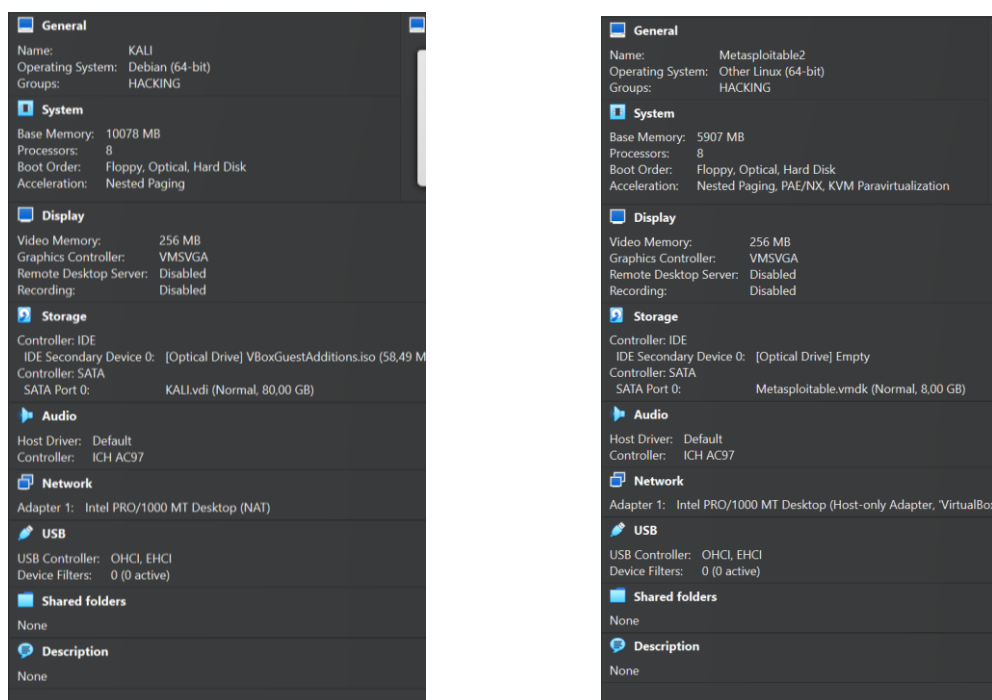


Figure 1: Virtual Lab Environment Setup in VirtualBox



Installation of Metasploitable

Metasploitable was configured as the vulnerable target system. It is an intentionally vulnerable Linux-based virtual machine designed for security training and testing.

The purpose of using Metasploitable is to simulate real-world vulnerable services, including:

- FTP services
- Web applications
- Database servers
- Remote execution services

This allowed realistic vulnerability scanning and risk analysis.

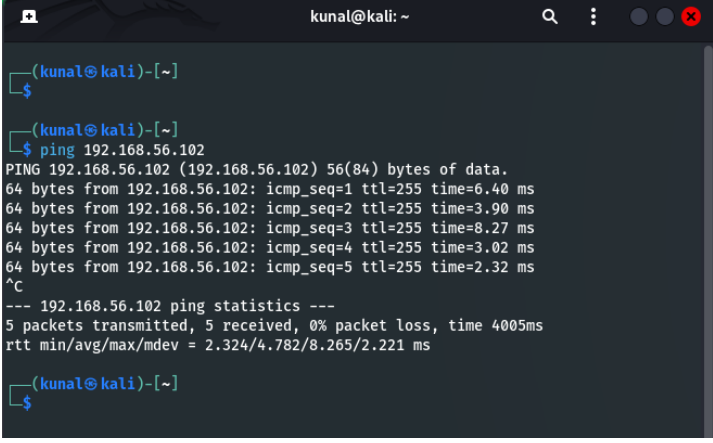
Network Configuration

Both virtual machines were configured using a Host-Only network adapter in VirtualBox to allow communication between Kali Linux and Metasploitable.

To verify connectivity, a ping test was performed from Kali Linux to the Metasploitable IP address.

Command used: *ping 192.168.56.102*

The successful ping response confirmed that both systems were correctly configured within the same network.



```
kunal@kali: ~  
(kunal@kali)-[~]  
$  
(kunal@kali)-[~]  
$ ping 192.168.56.102  
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.  
64 bytes from 192.168.56.102: icmp_seq=1 ttl=255 time=6.40 ms  
64 bytes from 192.168.56.102: icmp_seq=2 ttl=255 time=3.90 ms  
64 bytes from 192.168.56.102: icmp_seq=3 ttl=255 time=8.27 ms  
64 bytes from 192.168.56.102: icmp_seq=4 ttl=255 time=3.02 ms  
64 bytes from 192.168.56.102: icmp_seq=5 ttl=255 time=2.32 ms  
^C  
--- 192.168.56.102 ping statistics ---  
5 packets transmitted, 5 received, 0% packet loss, time 4005ms  
rtt min/avg/max/mdev = 2.324/4.782/8.265/2.221 ms  
(kunal@kali)-[~]  
$
```

Figure 2: Network Connectivity Verification Between Kali and Metasploitable

Environment Validation

After confirming network connectivity, both virtual machines were operational and ready for vulnerability scanning. The isolated lab ensured that all testing activities were conducted ethically and safely within a controlled environment.

This completed the setup phase of the practical assessment.



2. Vulnerability Scanning

After successfully setting up the testing environment, a vulnerability assessment was conducted on the Metasploitable machine using OpenVAS (Greenbone Vulnerability Manager). The objective of this phase was to identify security weaknesses, exposed services, and known vulnerabilities present in the target system.

OpenVAS is an open-source vulnerability scanning tool that detects misconfigurations, outdated software versions, default credentials, and publicly known CVEs. It also assigns CVSS scores to classify vulnerabilities based on severity.

Launching OpenVAS

OpenVAS was launched from Kali Linux and accessed through its web interface. The vulnerability feed was verified to ensure updated scanning definitions were available.

The target IP address (192.168.56.102) was added to the scanner, and a full vulnerability scan was initiated.

OpenVAS dashboard showing:

- Target IP added
- Scan task created
- Scan status completed

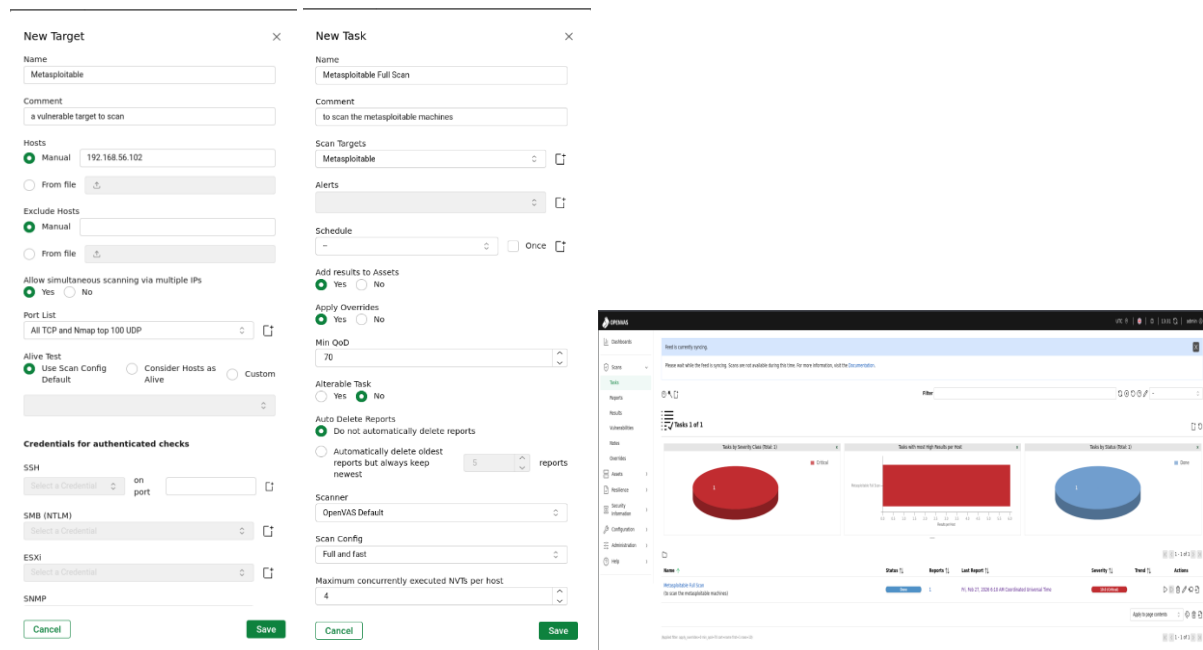


Figure 3: OpenVAS Scan Task Configuration



Scan Execution

A full and fast scan profile was selected to analyze all open ports and running services on the Metasploitable system.

The scanner performed:

- Port scanning
- Service detection
- CVE mapping
- Configuration analysis
- Authentication testing

The scan completed successfully and generated a detailed vulnerability report.

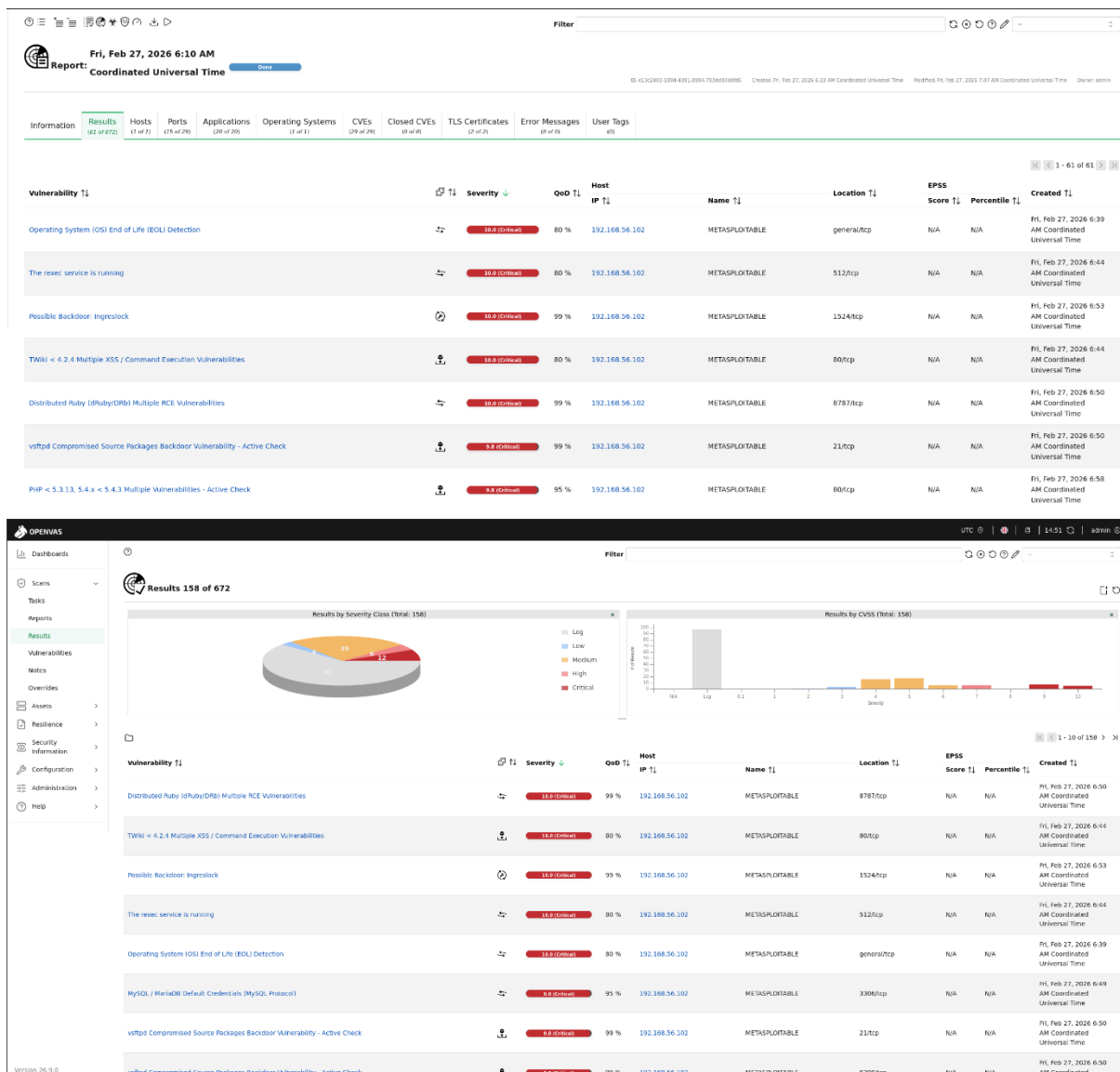


Figure 4: Vulnerability Severity Overview

- CVE reference
- CVSS score
- Affected port
- Service name
- Remediation recommendation

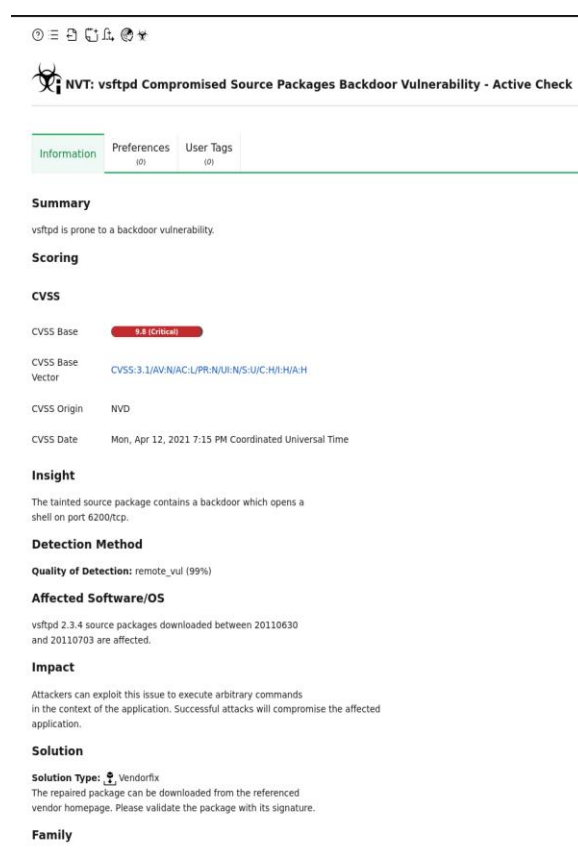


Figure 5: Example Critical Vulnerability Detail



Key Observations

The vulnerability scan revealed that the target system contained:

- 12 Critical vulnerabilities
- Multiple High severity vulnerabilities
- Several misconfigured services
- Weak authentication mechanisms

The presence of multiple critical vulnerabilities indicates that the system is highly insecure and vulnerable to compromise.

</



3. Document Findings

After completing the vulnerability scan, the identified findings were documented in a structured format to ensure clarity and proper risk tracking. Documentation helps convert raw scan output into an organized vulnerability register that can be used for remediation and reporting purposes.

Each vulnerability was recorded with the following attributes:

- Target IP address
- Affected port number
- Service name
- Vulnerability description
- CVE reference
- CVSS score
- Severity level

This structured documentation allows easy prioritization and management of security risks.

Target Information

Target System Details:

- Target IP Address: 192.168.56.102
- Operating System: Ubuntu 8.04 (End-of-Life)
- Scan Tool Used: OpenVAS
- Scan Type: Full and Fast Scan

Vulnerability Summary Table

IP Address	Port	Service	Vulnerability	CVSS	Severity
192.168.56.102	21	FTP (vsftpd)	Backdoor Vulnerability	9.8	Critical
192.168.56.102	3306	MySQL	Default Credentials	9.8	Critical
192.168.56.102	5432	PostgreSQL	Weak Password	9.0	Critical
192.168.56.102	1524	Ingreslock	Backdoor Service	10.0	Critical
192.168.56.102	80	HTTP (PHP CGI)	Remote Code Execution	9.8	Critical

Figure 6: Documented Vulnerability Summary Table



Categorization of Findings

The identified vulnerabilities were categorized based on severity levels:

- Critical: Remote code execution, backdoors, default credentials
- High: Insecure HTTP methods, SSL vulnerabilities
- Medium: Unencrypted services, weak configurations
- Low: Minor configuration issues

Importance of Structured Documentation

Documenting vulnerabilities in a structured format ensures:

- Easier risk tracking
- Better communication with stakeholders
- Clear remediation roadmap
- Alignment with compliance requirements



4. Practice Risk Assessment

After documenting the identified vulnerabilities, a structured risk assessment was performed to prioritize remediation efforts. Risk assessment combines technical severity (CVSS score) with practical business impact and likelihood of exploitation.

Two approaches were used:

- CVSS-based severity classification
- 3x3 Risk Matrix (Likelihood vs Impact)

CVSS-Based Risk Classification

The Common Vulnerability Scoring System (CVSS) scores provided by OpenVAS were used to determine the severity of vulnerabilities.

Severity scale used:

- Critical: 9.0 – 10.0
- High: 7.0 – 8.9
- Medium: 4.0 – 6.9
- Low: 0.1 – 3.9

The scan revealed multiple Critical vulnerabilities with CVSS scores above 9.0, indicating extremely high exploitability and severe impact.

Examples:

- vsftpd Backdoor → CVSS 9.8
- Ingreslock Backdoor → CVSS 10.0
- MySQL Default Credentials → CVSS 9.8

These vulnerabilities require immediate remediation.

3x3 Risk Matrix (Likelihood vs Impact)

A risk matrix was created to further prioritize vulnerabilities based on two key factors:

- Likelihood of exploitation
- Impact if exploited

Likelihood ↓ / Impact →	Low Impact	Medium Impact	High Impact
High Likelihood	Medium Risk	High Risk	Critical Risk
Medium Likelihood	Low Risk	Medium Risk	High Risk
Low Likelihood	Low Risk	Low Risk	Medium Risk



Vulnerability Risk Classification

After constructing the 3x3 risk matrix, the identified vulnerabilities were mapped according to their likelihood of exploitation and potential business impact. This approach ensures that remediation efforts are prioritized based on real-world attack probability and severity of consequences.

The following key vulnerabilities were classified:

vsftpd Backdoor (Port 21)

- Likelihood: High
- Impact: High
- Risk Level: Critical Risk

This vulnerability allows remote attackers to gain shell access to the system. Since public exploit code exists and authentication is not required, it represents a severe and immediately exploitable threat.

MySQL Default Credentials (Port 3306)

- Likelihood: High
- Impact: High
- Risk Level: Critical Risk

The presence of default or weak database credentials enables attackers to access sensitive data. This could lead to full database compromise, data leakage, or privilege escalation.

Anonymous FTP Login (Port 21)

- Likelihood: Medium
- Impact: Medium
- Risk Level: Medium Risk

Anonymous access increases the exposure surface of the system. While it may not directly lead to full compromise, it can assist attackers in reconnaissance or information gathering.

HTTP PUT Method Enabled (Port 80)

- Likelihood: Medium
- Impact: High
- Risk Level: High Risk

The HTTP PUT method may allow attackers to upload malicious files to the web server, potentially leading to remote code execution if combined with other weaknesses.



Risk Prioritization Strategy

Based on the assessment, vulnerabilities were prioritized in the following order:

1. Critical vulnerabilities (RCE, backdoors, default credentials)
2. High severity vulnerabilities (insecure services, SSL weaknesses)
3. Medium severity vulnerabilities (configuration weaknesses)
4. Low severity vulnerabilities (minor exposure issues)

This prioritization ensures that the most dangerous threats are addressed first.

Conclusion

The objective of this security assessment was to identify vulnerabilities present in the Metasploitable virtual machine within a controlled lab environment. The assessment was conducted using Kali Linux and OpenVAS to simulate a real-world vulnerability assessment process.

The scan results revealed multiple critical vulnerabilities, including remote code execution flaws, default credentials, exposed services, and insecure configurations. Several vulnerabilities were rated with CVSS scores above 9.0, indicating high exploitability and severe impact.

The presence of backdoor services and weak authentication mechanisms demonstrates that the system is highly insecure and susceptible to compromise. Immediate remediation is required to prevent unauthorized access and potential data breaches.

This assessment demonstrates the importance of proactive vulnerability management and structured risk prioritization in maintaining secure systems.